Computers & Industrial Engineering 198 (2024) 110652



Contents lists available at ScienceDirect

Computers & Industrial Engineering

journal homepage: www.elsevier.com/locate/caie





Unmasking phishers: ML for malicious certificate detection

Magnea Haraldsdóttir [a], Sajad Homayoun [b,*], Emil Lynge [a], Christan D. Jensen [c]

[a] Muninn ApS, Kongens Lyngby, 2800, Denmark
[b] Cyber Security Group, CMI Section, Department of Electronic Systems, Aalborg University, Copenhagen, 2450, Denmark
[c] Department of Electrical and Computer Engineering, Aarhus, 8200, Denmark

ARTICLE INFO

Keywords:
Phishing
Digital certificates
Domain names
Natural language processing

ABSTRACT

Phishing attacks increasingly use digital certificates to appear safe to users, and the frequency of such attacks has surged in recent years. As an example, around 80% of the 2021 phishing attacks used digital certificates to appear legitimate. The most common methods today for detecting phishing websites rely on users reporting the websites to phishing repositories, where they are then confirmed. This process can be slow, allowing the attacker to have time to have their phishing attack out on the Internet. Newer methods that implement machine learning models for the detection of phishing websites based on their digital certificate have been shown to be effective. This paper presents a system that uses certificate and domain name related features along with machine learning methods for the detection of phishing websites. To develop the system, data was collected from PhishTank and Tranco for domain names, and Censys was used for certificate retrieval. The domain related features are partly engineered using a time-series based deep learning model to get a vector representation of the domain name. Using the features engineered from the certificate and domain name, classical machine learning classifiers are trained and compared. Enriching the feature set with the vector representation of the domain names results in higher performance in distinguishing suspicious certificates from benign ones, going from an F1-score of 0.77 for a feature set solely based on certificate-related features to a performance of 0.89 with the enriched feature set. A time-based evaluation reflects the same performance with an F1-score of 0.88, which is an improvement compared to existing approaches to feature engineering.

1. Introduction

Phishing attacks have been on the rise in recent years, so much that they are the most common cyber attack monitored by the FBI (FBI Internet Crime Complaint Center, 2022). Previously a user could depend on the padlock icon in their browser to be sure that they were passing on sensitive information through a secure website. Today, using HTTPS, which is what gives a website the padlock in browsers, can no longer be considered a good enough indicator for the safety of the website. This is due to the fact that most attackers have started using HTTPS in their attacks, fooling users with a false sense of security from the lock icon (Phishing Activity Trends Report, 2021). The Federal Trade Commission of the USA advises people to be aware of the methods used by phishing attacks (Federal Trade Commission, 2022). There exist repositories of phishing websites, such as PhishTank[1] but for a phishing website to appear in these types of list someone needs to have been or almost have been a victim of the attack. This is due to the fact that these phishing lists are user driven, someone has to report it before it is confirmed to be a phishing website.

Therefore, cybersecurity researchers have been working to propose more advanced techniques for detecting phishing activities. For example, Salahdine, El Mrabet, and Kaabouch (2021) proposed a machine learning-based approach to detect phishing attacks by analyzing phishing emails and modeling them with relevant features. Their approach showed significant improvement in detection accuracy using an artificial neural network. Similarly, Karim, Shahroz, Mustofa, Belhaouari, and Ramana Kumar Joga (2023) developed a phishing detection system based on URL features, employing a hybrid machine learning model combining logistic regression, support vector machines, and decision trees to achieve high detection accuracy. In another study, Tyagi, Shad, Sharma, Gaur, and Kaur (2018) focused on using various machine learning algorithms to predict the legitimacy of websites, achieving a remarkable precision of 98.4%. Aljabri and Mirza (2022) further explored the application of machine learning and deep learning techniques to detect phishing websites, emphasizing the importance of feature selection to enhance model performance. Despite these advancements, our work differentiates itself by specifically targeting HTTPS phishing attacks. We aim to detect phishing by analyzing digital

* Corresponding author.
E-mail address: sajadh@es.aau.dk (S. Homayoun).
[1] https://phishtank.org/.

https://doi.org/10.1016/j.cie.2024.110652
Received 2 June 2024; Received in revised form 24 September 2024; Accepted 10 October 2024
Available online 18 October 2024
0360-8352/© 2024 The Authors. Published by Elsevier Ltd. This is an open access article under the CC BY license (http://creativecommons.org/licenses/by/4.0/).

certificates, an area that has not been explored as thoroughly but is becoming increasingly important as more malicious actors adopt HTTPS.

Previous work has shown that it is a feasible idea to classify certificates as phishing certificates and benign certificates. Policies and best practices regarding certificate usage for websites are always evolving, and this could affect the trends that distinguish phishing certificates from benign ones. The benefit of using data based on the certificates of a website is that it is easily available data even without entering the website through tools like Censys (Durumeric, Adrian, Mirian, Bailey, & Alex Halderman, 2023) or OpenSSL. However trends in certificate usage are changing, for example Google has proposed that it will move from recommending certificates be valid for 398 days to 90 days.[2] This change in Google's recommendation could impact the effectiveness of using certificates in phishing detection, as can be seen in the data exploration in this paper. Therefore, this paper will focus on expanding the feature sets already proposed in previous work by building features based on domain names. The goal is to implement a machine learning algorithm that can classify a website as benign or phishing based only on its certificate and domain name. By adding domain-related features, the goal is to further improve the methods already proposed in previous work.

Our advanced domain-related features are built using a natural language processing (NLP) approach with a popular method used for NLP called bidirectional long-short-term memory (BiLSTM). The BiLSTM model is used to extract a vector representation of the domain names, and these vector representations of the domain names are used to expand the features of the certificate. With the feature set, classifiers using Random Forest, K-Nearest Neighbors, and Support Vector Machine are trained to establish the best performing model and features. The evaluation is done by comparing common performance evaluation metrics such as the F1 score, accuracy, Recall, Precision, and confusion matrix. A time-based evaluation is also conducted to see how well the classifier generalizes over time. The evaluations show that enriching domain-related features improves the performance of distinguishing phishing certificates.

In this paper a systematic review of the literature is presented in Section 2, followed by a chapter on data collection and feature engineering in Section 3. The methodology and results are explained in Sections 4 and 5, respectively. Section 7 describes the symbols and abbreviations used in the paper, and finally Section 8 concludes the paper.

2. Literature review

In this section, the systematic review of the literature is presented following a structured review protocol. The topics of interest are explored for all the papers, that is, the methods used, data sources and labeling, and finally feature engineering.

2.1. Review process

The repositories that were searched are IEEE Xplore, ACM Digital Library, Web of Science, and Scopus. Each of these repositories have their own query language, but the queries are constructed such that in the document title the keywords "certificate/s" or "digital certificate/s" must be mentioned. Then there are two groups of conditions for the abstract. The first is that one of the keywords "phishing", "malicious", or "suspicious" must be present in the abstract. This is to ensure that the literature we search for actually addresses malicious certificates. The second condition is that we require one of the following to also be in the abstract, "detection", "identification", "machine learning", "deep learning", "supervised" or "unsupervised". This is to ensure that the methodology is a machine learning-based approach. All the information from the queries was extracted from the four libraries on 23 September 2024.

[2] https://www.chromium.org/Home/chromium-security/root-ca-policy/moving-forward-together/.

Table 1
Inclusion and quality criteria.

Id	Criteria
IC1	The paper is focused on malicious or phishing certificates
IC2	The paper is focused on detection preferably using some machine learning algorithm
IC3	The paper utilizes different elements of the certificate as data
QC1	The goal of the paper is clear

Table 2
Number of papers identified in each repository.

Repository	No. of papers
IEEE Xplore	15
ACM Digital Library	68
Web of Science	44
Scopus	38

In the literature search, a checklist proposed in the PRISMA-S statement (Rethlefsen et al., 2021) is followed. PRISMA-S is an extension of the PRISMA statement (Page et al., 2021) to provide researchers with a checklist to carry out searches reproducibly.

The review protocol will be:

1. Search repositories
2. Remove duplicates
   (a) Remove duplicates based on DOI
   (b) Remove duplicates based on Title
3. Remove irrelevant papers based on the paper abstract

When removing irrelevant papers based on the abstract, the inclusion criteria (IC) and quality criteria (QC) listed in Table 1 will be followed.

In Table 2, we have the number of papers identified in each repository. Fig. 1 shows the PRISMA flow chart of the systematic review. In total, we started with 165 papers. We found 61 duplicates, and then 89 papers were excluded in the abstract selection.

When screening the abstract, the most common reasons for removal were that the papers covered certificate uses in other domains than HTTPS. The main topics were certificates used in vehicular ad hoc networks, mobile ad hoc networks, or certificateless cryptography.

After evaluating all papers, 5 papers were excluded for two different reasons. The first reason (R1) was an almost complete duplicate that was not identified in the removal of duplicates. This is because the papers had different titles and DOI, but were by the same authors and contained almost all the same information. The paper containing more information is therefore only taken into account in the review. The second reason (R2) was that machine learning and certificate-related features were not really used or were lacking quality, thus not satisfying IC2 and IC3 or QC1. For example, the authors in Ishida, Hanada, Waseda, and Kim (2023) focused on building DNS graphs of phishing websites using Certificate Transparency logs, without using certificate or domain-related features. Although this method revealed key differences between benign and phishing sites, it could miss important details such as certificate validity or domain history that could improve detection. Including these features could enhance the system's ability to spot phishing threats more effectively.

2.2. Methods previously used

Most of the papers identified have focused on a binary classification approach, either the certificate is malicious/phishing or it is benign.

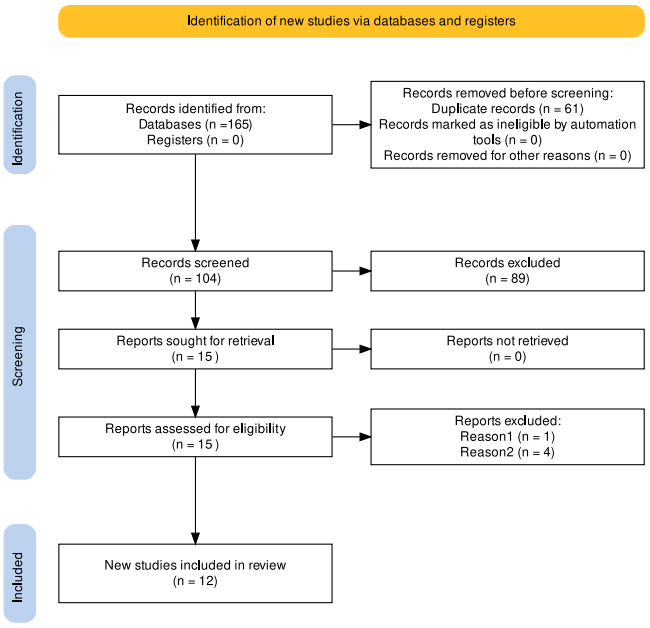


Fig. 1. PRISMA flow chart.

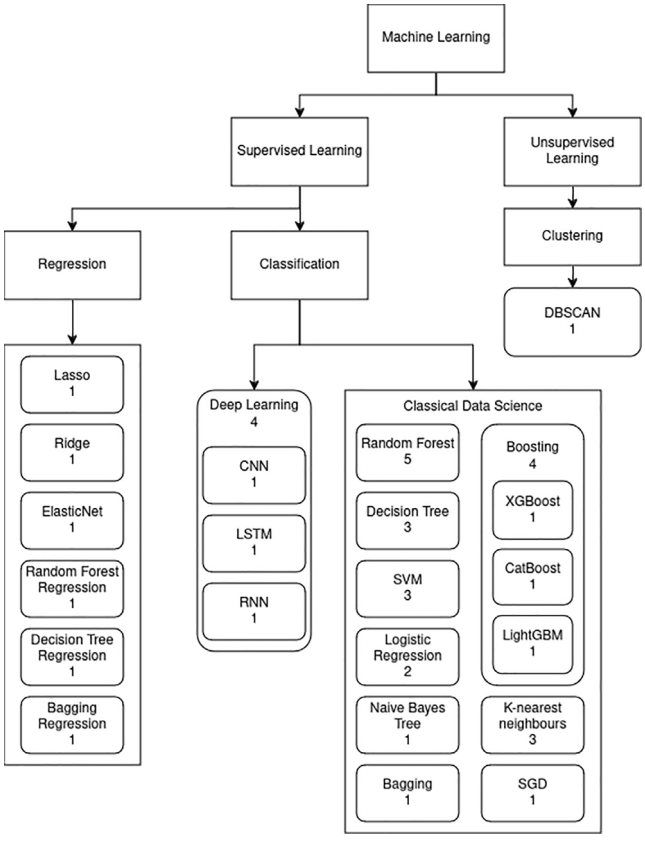


Fig. 2. Number of papers per algorithm.

There have been attempts at multiclass classification, where there has been a third category for medium risk certificates (Hawanna, Kulkarni, Rane, Mestri and Panchal, 2016). It seems to be the general conclusion that Random Forest (RF) methods outperform other classical and ensemble Machine Learning methods (AlSabah, Nabeel, Boshmaf, & Choo, 2022; Dong, Kapadia, Blythe, & Jean Camp, 2015; Hawanna, Kulkarni, Rane and Joshi, 2016; Homayoun, Hageman, Afzal-Houshmand, Jensen, & Pedersen, 2022). There has also been research on the use of neural networks to solve this problem (Drichel, Drury, Brandt, & Meyer, 2021; Li, Zhang, & Guo, 2021; Torroledo, Camacho, & Bahnsen, 2018). The performance of using neural networks has been similar to the Random Forest implementations, although it is stated that with Neural Network approaches feature engineering is not necessary but Drichel et al. (2021) still use the features engineered for the RF implementation as an encoding for the certificate. Fig. 2 provides an overview of the algorithms used in the articles identified in the literature review and how many papers use each algorithm. Moreover, they have been divided into their respective branches of machine learning.

2.3. Data sources and labeling

Most researchers used Alexa to collect benign URLs, but Alexa is no longer maintained (Burton, 2022), so in more recent articles, Tranco (Pochat, Goethem, Tajalizadehkhoob, Korczyński, & Joosen, 2019) has become a popular choice for top domains. PhishTank and OpenPhish[3] were the most popular providers of malicious URLs. To collect the certificates, OpenSSL or Censys (Durumeric et al., 2023) was used.

Some papers take the approach of having three categories of data. There is always a malicious category based on blocklists like PhishTank. Then for benign certificates two categories are constructed, one based on lists such as Alexa or Tranco, and then another benign list based on domains that receive low traffic but are not yet part of any phishing blocklists (AlSabah et al., 2022; Hageman, Kidmose, Hansen, & Pedersen, 2021). AlSabah et al. (2022) show how the properties of popular and unpopular benign certificates vary, which gives reason for having these three categories in the data set.

In Hageman et al. (2021) and Homayoun et al. (2022) the problem of defining a ground truth is explained. When building a dataset solely on certificates, multiple domain names can be attached to the certificate through the SANs or a wildcard domain. In Homayoun et al. (2022) a certificate was labeled phishy or benign if the SANs only included phishing or benign domains, respectively, or unlabeled domains. A certificate is labeled conflicted if it contains both a benign and a phishing domain on the SANs. This challenge of a ground truth is something that needs to be considered, and the possibility of conflicted certificates is something that needs to be checked.

2.4. Feature engineering in previous work

It is important to analyze the features used in previous work to gain an overview of what has been done and what has worked well. As the interest lies in domain-based features, there is a special focus on previous work on domain-related features.

Dong et al. (2015) built the dataset solely based on certificate features, along with the check if the domain of the website is the same as the subject common name. An important feature they use are temporal features based on the `not_before` and `not_after` fields from the certificate. Their arguments for why these are important features do not apply anymore as the best practice of certificate creation is moving towards shorter and shorter validity period in certificates, making temporal features less useful in the detection of phishing certificates. The check for the match between domain and subject common name is also not that useful as the use of SANs has increased.

Fasllija, Enişer, and Prünster (2019) introduce suspicious keywords and TLD based features are used on the basis that using some keywords in the subdomains or a trusted TLD as a subdomain can fool the user

[3] https://cortex.marketplace.pan.dev/marketplace/details/OpenPhish/.

into thinking the site is legit. They also calculated the Shannon entropy to measure the randomness of a domain.

Hageman et al. (2021) implement domain-related features where individual predictions are made for each domain in the SANs and the individual predictions are then combined in a metaclassifier using maximum, min, average and median. This is done because the goal is to be able to classify certificates on their own and not have a specific domain linked to the certificate.

Homayoun et al. (2022) build on the feature sets from Drichel et al. (2021), Fasllija et al. (2019) and Li et al. (2021) and combine the features from all papers into a bigger dataset. The domain related features are all lexical based features aggregated over the domains in the SANs.

The feature set by Li et al. (2021) is partially built on the certificate chain, which requires the solution to establish the entire certificate chain for each certificate.

Efforts to develop a clustering algorithm have been made by Sakurai, Watanabe, Okuda, Akiyama, and Mori (2020). The clustering algorithm was used on the subject common name in the certificate to establish a set of templates that can then be used to cluster new unseen certificates.

AlSabah et al. (2022) explored using Passive DNS features along with certificate and domain features. Using the Passive DNS features does show a positive affect on the FPR when classifying the certificates.

2.5. Literature review conclusions

With the exception of Drichel et al. (2021), Fasllija et al. (2019) and Homayoun et al. (2022) there has been little exploration of the domain name and features based on the domain. The features proposed in Homayoun et al. (2022) are all lexical-based features. This means that there is an opportunity to explore more advanced features based on domain names. Furthermore there is an opportunity to explore NLP based approaches to feature extraction on the domain names.

Even though some good features can be extracted from the chain of the certificate or by using passive DNS features, it requires more work in the data gathering for prediction of a single certificate. This is where exploring more advanced domain related features is an interesting idea, it could provide more insight without having to gather more data than the domain name and its corresponding certificate.

3. Data

This section covers everything related to the data used in the paper. First the data collection process is covered as well as the data sources used. The data is then cleaned and labeled, and finally a data exploration is presented.

3.1. Data sources and collection

To establish a set of benign domains a list from Tranco (Pochat et al., 2019) was extracted on the 30. October 2023. Tranco is a research-oriented project that collects the top 1 million domains over the last 30 days. This is done by combining the rankings from other providers, which all have their own methods of calculating the popularity. Tranco then combines these with the goal of providing a more stable top 1 million domain list. The top 20,000 domains from the Tranco list are selected to be used as the list of benign domain names.

To establish a set of phishing domains, a list of valid online phishing URLs was collected from PhishTank on the 30. October 2023. PhishTank is a site where anyone can report a phishing website. Then a community of people will verify these suspected phishing sites. Only URLs using the HTTPS protocol are extracted, as those are the only ones of interest. Under the assumption that domains in the Tranco list are benign due to their popularity, certificates associated with them cannot be deemed as phishing certificates. There is an overlap in the phishing URL list extracted and the Tranco list created but this is due to user-generated phishing attacks. This can for example be a file stored in Google Drive, the file might rightly be a phishing attack, but that does not mean that the certificate associated with the Google Drive website should be considered malicious. After filtering the extracted list from PhishTank there are 26,268 URLs in the list. The root domain is used as a the domain of interest, for example https://www.example.com/path will become `example.com`. The Tranco list is already in this format.

Using a certificate dataset from Censys, certificates are extracted for the domain names from the gathered data from PhishTank and Tranco. The certificate dataset from Censys is the most exhaustive in existence (Durumeric et al., 2023).

When certificates are saved in their datasets, Censys does some processing of the certificates. They parse or decode the certificates so that they store all the information contained within the certificate. Additionally, they store information from major root stores such as Apple, Google Chrome, Microsoft, and Mozilla NSS among other information not utilized in this paper. Table 3 shows a snippet of the attributes and their values from the Censys dataset. Due to the large number of attributes, it is not feasible to display all of them in the manuscript. We therefore refer the reader to the Censys documentation for a comprehensive list of attributes.

Table 3
Sample certificate data (Some attributes omitted for brevity. For full details, see Censys documents).

Attribute	Value
fingerprint_sha256	a1b2c3d4e5f67890...eff0000
issuer_organization	Example Corp Inc.
subject_common_name	www.example.com
validity_period_start	2023-01-01T00:00:00Z
validity_period_end	2024-01-01T00:00:00Z

The data collection procedure is that a query was run against the Censys dataset for the fields of the certificate of interest in this paper where the parameter `not_valid_after` is after 1. January 2023 and before 1. January 2024. These dates are chosen because with the amount of data available in the certificate datasets from Censys we needed to limit the search for certificates, but we also want the certificates that are found to be as new as possible to have a dataset that represents current trends as much as possible. These results are then matched to the Tranco and phishing list on the field `names`, if there is a match that certificate is kept. Using this procedure 1,900,001 certificates were collected. Due to the nature of the data collection process and the dataset provided by Censys, the collection of certificates established contains duplicates and can contain multiple certificates matching to the same domain. Processing and cleaning is therefore required.

Another set of phishing domains needs to be established to build a model for enhancing the domain related features. A list of phishing domains was extracted on the 9. January 2024. After processing the new phishing URL list in the same manner as was done with the list for certificate collection, all certificates contained in both lists are removed. This is to ensure that the phishing domains used for the domain-based model training are not in the certificate dataset. This list has 25,146 phishing URLs. The establishment of a new Tranco based benign list is not as straight forwards as the most popular domains tend to stay the most popular so fetching a new Tranco list and taking the top domains might result in a lot of the same domains as are in the certificate dataset. Instead the top 50,000 domain names are selected and from those 50,000, 25,000 are randomly sampled. This results in a dataset consisting of 50,146 labeled domains.

3.2. Data cleaning and labeling

When exploring the certificate collection, a substantial amount of certificates with identical subject common name were observed. It

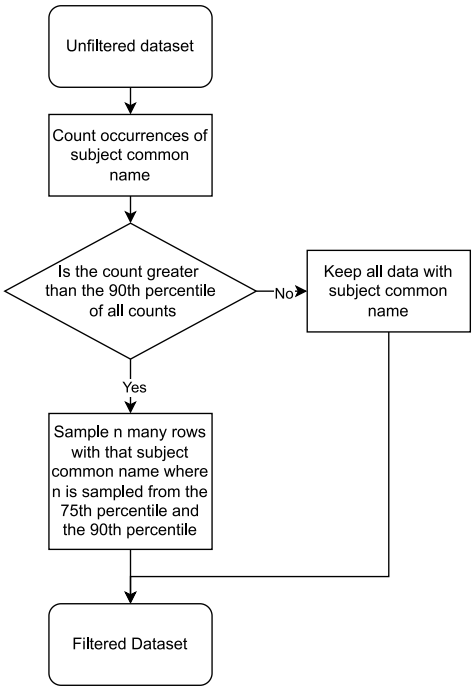
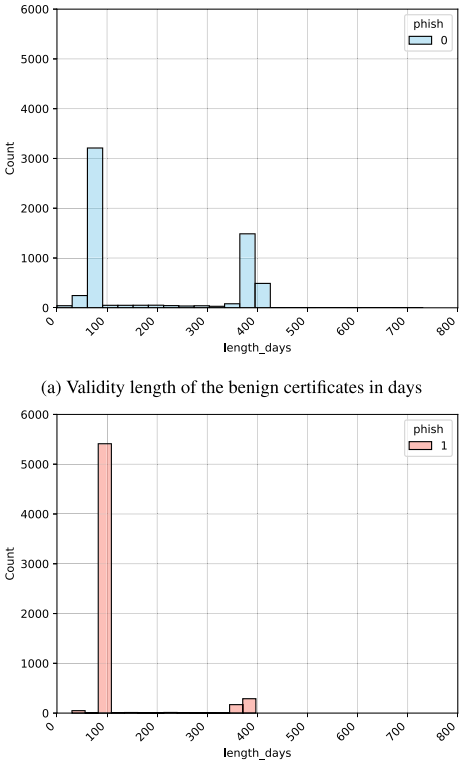


Fig. 3. Filtering process to reduce duplicates of certificates with the same subject common name.



(a) Validity length of the benign certificates in days

(b) Validity length of the phishing certificates in days

Fig. 4. Distribution of the validity length (length_seconds) converted to days for easier reading.

cannot be assumed that all certificates with the same subject common name will be duplicates but including all these certificates, even though they are individual certificates, they come from the same origin and display the same features when processed. Duplicates of the subject common name are reduced with the procedure explained in Fig. 3. This process reduced the dataset to 79,196 from 1,900,001 certificates. This drastic drop in certificates is mostly due to one subject common name appearing 1,647,210 times in the dataset and a few others that have a high number of repetitions in the dataset. This process does not completely eliminate duplicates in the dataset but is used as an initial cleansing to reduce the size of the dataset to a manageable size.

To establish a ground truth, i.e. label the data, each certificate collected is linked to the domain it matched to when collecting the certificates from Censys. This is done separately for the Tranco domains and the phishing domains. This results in some certificates matching to multiple domain names from either list and in some cases they match both lists. In the case of the multiple matches, 786 were phishing matches, 1955 Tranco matches and 193 had both phishing and Tranco matches, with multiple domain matches. After analyzing the amount and the origin of these certificates with multiple matches it was deemed safe to drop them. Big portion of the phishing ones that were dropped come from various hosting services that slipped the initial filtering of the phishing list. The dataset includes more Tranco matches so dropping the certificates with multiple Tranco matches should not impact the amount of data in any significant way. In the case of exactly one match to both Tranco and the phishing list there were 426 certificates, After inspecting the certificates it was clear that these can be considered as benign certificates with user-generated phishing material, just as was done for the initial data cleaning on the PhishTank list, therefore they are dropped. Dropping certificates that match both a phishing domain and a Tranco domain can, of course, affect the data by removing these edge cases from the model development. This could result in a model that is unable or has poor performance when presented with these edge cases, and therefore should be considered before this type of model is used in real-world applications. However, these certificates are considered to not be a huge part of the established dataset and therefore not necessary to determine the impact of adding domain related features which is the goal of this paper. This leaves every certificate only being matched to a phishing domain or a benign domain and the data can be labeled.

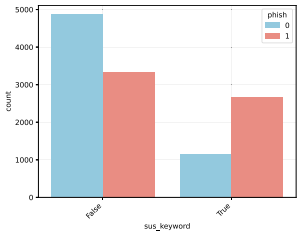
After data cleaning and labeling, the final dataset includes 12,016 labeled certificates with an equal amount of phishing and benign certificates, which means that the dataset is balanced. We did a sampling to achieve a balanced dataset. The set of features includes 28 features based only on certificates, 17 features based on the SAN, and 19 features based on the lexical properties of the domain name. An overview of the features can be found on GitHub.[4]

3.3. Data exploration

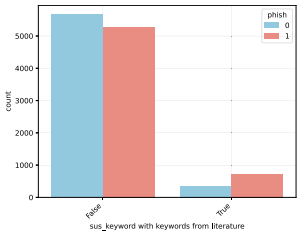
The distribution of the validity period of the certificates can be seen in Fig. 4. Fig. 4(a) shows how it is most common for benign certificates to be valid for 90 days or around a year where as for the phishing certificates, Fig. 4(b) shows how almost all phishing certificates have a validity period of 90 days. This feature is likely to stop giving any insights into whether a certificate is phishing or not if Google go trough with their plans to only support 90 day certificates in Chrome.

In Drichel et al. (2021) and Fasllija et al. (2019) lists of keywords are proposed as suspicious keywords. In Fasllija et al. (2019) the list is based on famous applications of social networks, commerce, or cryptocurrency, as this is a known phishing technique, that is, including known words to confuse the user. In Drichel et al. (2021), the keywords are based on a list of PhishTank URLs. To test whether trends in phishing domains have changed, a new keyword extraction based on a PhishTank extraction was performed. This list of phishing URLs does not overlap any phishing URLs used to build the certificate dataset, this

[4] https://github.com/magneaharalds/UnmaskingPhishers.

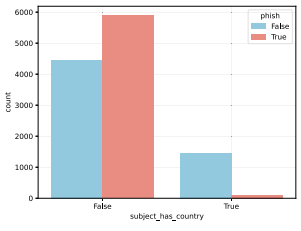


(a) Number of suspicious keywords per phishing and benign certificates with newly generated keywords

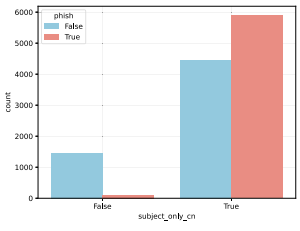


(b) Number of suspicious keywords per phishing and benign certificates with keywords from the literature.

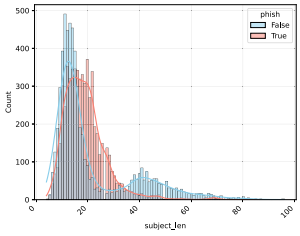
Fig. 5. Distribution of the suspicious keywords and comparison with different keyword lists.



(a)



(b)



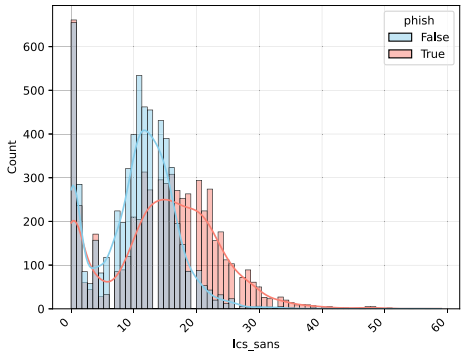
(c)

Fig. 6. Distribution of features based on the subject field of the certificates.

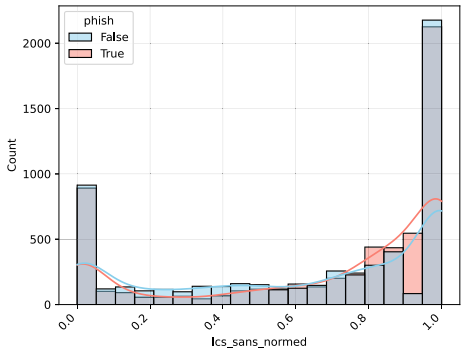
is done to make sure that the feature is not built on and applied to the same data. Similarly to Drichel et al. (2021), the URLs are split into dots and the TLD is removed before extracting keywords using TF-IDF (Leskovec, Rajaraman, & Ullman, 2020), where the frequency of the term is calculated for words after removing the stopwords from the English language. The words are built from the domains in the same way as is explained in Fig. 10(a). To compare the lists of keywords from the literature and the generated keywords, the suspicious keyword feature is built for each of the lists and the distribution of each can be seen in Fig. 5. There is a clear difference between Figs. 5(a) and 5(b), suggesting that to maintain the proposed system, the keywords must be updated as time passes. In model building, the keyword matching used is the one developed in this paper.

The distribution of features based on the subject field of the certificates can be seen in Fig. 6. Even though it is more common for benign certificates to have only the common name part of the subject field, there is still a good amount of certificates that have other parts of the subject field. An example is the country in the subject, see Fig. 6(a), where a good proportion of benign certificates have that field where as the phishing certificates almost only have the common name filled out in the subject. This is then reflected in the length of the subject, Fig. 6(c), where benign certificates have two peaks in the distribution of the length feature.

Fig. 7(a) shows how the distribution of the longest common subsequence varies between benign and phishing certificates. Benign certificates seem to have longer common sub-sequences than phishing certificates but when contrasted with the *lcs_sans_normed* feature in



(a)

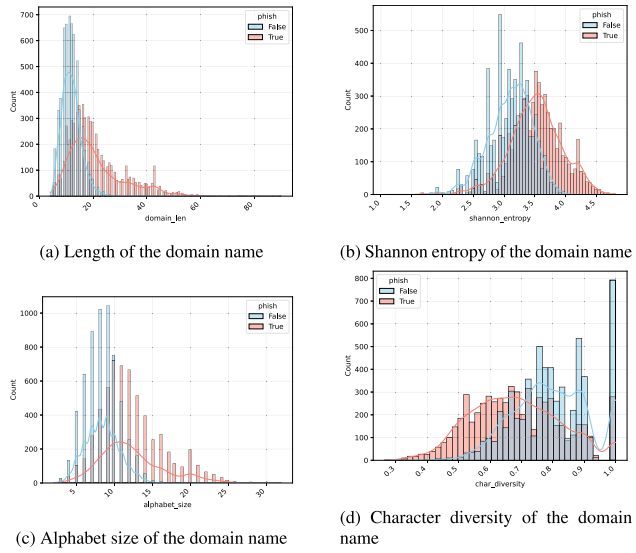


(b)

Fig. 7. Distribution of the longest common sub-sequence (LCS) of the SANs for each certificate and the LCS normed to the longest domain in the SAN list.

Fig. 7(b), there seems to be not as a drastic difference in the distributions between the two groups. The ranges on the *y*-axis vary between the two figures (0–600 in Fig. 7(a) and 0–2000 in Fig. 7(b)) due to differences in the count distributions of the raw LCS values versus the normalized LCS values. In Fig. 7(a), the counts for the raw LCS values are generally lower, with no bin exceeding 600, which is why the *y*-axis is scaled from 0 to 600. In Fig. 7(b), the normalized LCS values have higher frequencies, particularly with a significant peak at the normalized value of 1.0, resulting in counts that exceed 2000. Therefore, the *y*-axis range is scaled from 0 to 2000 to accommodate these higher counts.

Fig. 8 displays various features based on the lexical domain. Here, it can be seen that there is a difference in the distributions of the features depending on the phishing and benign domains. In fact, when a t test is performed on the two groups, see Table 4, there is a significant difference between the groups for the four variables shown in Fig. 8. This indicates that using lexical features based on the domain will help solve the classification problem. Fig. 8(a) shows how it is more common for phishing domains to have longer domain names. Fig. 8(b) shows how it is more common for phishing domains to have a higher Shannon Entropy compared to benign domains. The Shannon entropy measures the randomness or uncertainty in a random variable. In this case a high Shannon entropy implies that the domains are more random, that is, phishing domains tend to be more random than benign certificates. This is also reflected in Fig. 8(c), where phishing certificates tend to have a larger alphabet, that is, they have more unique letters in the domain, although this could be a consequence of the domain being usually longer. Fig. 8(d), on the other hand, shows a lower trend in character diversity for phishing domains compared to benign domains. This could again be a result of longer domain names, and therefore it would have more repeats of characters. These differences in domain names between the two categories are good indicators that exploring further feature engineering based on the domain name could be a beneficial effort in the task of distinguishing benign and phishing certificates.



(a) Length of the domain name

(b) Shannon entropy of the domain name

(c) Alphabet size of the domain name

(d) Character diversity of the domain name

Fig. 8. Distribution of various lexical domain based features.

Table 4
Results of a t-test between the phishing and benign certificates, where DoL: domain length, ShE: shannon entropy, AlS: alphabet size, ChD: char diversity. The null hypothesis in this case is that there is no significant difference in the expected values of the two different groups. Taking a 0.05 significance level the hypothesis is rejected and the conclusion is that there is a significant statistical difference between the means of the groups.

	DoL	ShE	AlS	ChD
t-statistic	70	55	62	−47
p-value	<.00001	<.00001	<.00001	<.00001

4. Method

This section covers the proposed solution and its components. The proposed solution pipeline is shown in Fig. 9. As can be seen, there is a domain model component; this component is built on domain names alone and uses a BiLSTM model to create features based on the domain name. The raw certificates need processing, and that is where the feature engineering component comes in. As can be seen in Fig. 9, the feature space is two-fold, there are the certificate features and then the lexical features of the domain name and the SANs. This means that the feature set is considered as a pair between the domain name and a certificate connected to the domain name. Finally, there is the classification component that takes the output of the domain model and the engineered features and classifies the {certificate, domain} pairs. For the classification component, three classification algorithms are tested, Random Forest, K-Nearest Neighbors, and Support Vector Machines.

4.1. Domain based model for feature engineering

This subsection covers how to create sentences from domain names and treat the classification of domain names as an NLP problem. This classification model is then used to generate features based on the domain name. We use BiLSTM models as they have proved useful for NLP problems such as sentiment analysis and text classification. In this paper, the focus is only on BiLSTM models, since the goal is to provide a proof-of-concept that enhancing the feature set in this way can improve the classification of phishing websites.

The techniques and model structure used for sentiment analysis of text can be used to classify the domains. The text to be classified will be so-called domain sentences, where each sentence is based on a domain name. To build these domain sentences a method called word segmentation is used. In this paper, the word segmentation used is the Python package[5] based on the chapter *Natural Language Corpus Data* by Peter Norvig in the book *Beautiful Data* (Segaran & Hammerbacher, 2009).

The sentences are built by splitting the domain on "." to get the parts of the domain. Word segmentation is then used on the parts of the domain to get the words from the domain. Once the domain has been divided into words, a sentence is built. This process can be seen in Fig. 10(a). Examples of this process applied to domain names from the dataset can be seen in Figs. 10(b) and 10(c).

The BiLSTM model is built as a classification model and the performance can therefore be measured in accuracy and loss. To create new features based on the classification model, the second last layer of the BiLSTM model is extracted, and the outputs of that layer are calculated for each domain sentence in the certificate dataset. These new features can then be used as inputs into classification algorithms and will be referred to as vector representations of the domain name.

5. Results

This section covers the results of the model building. First, we cover the results of the BiLSTM model for domain names and then the classification models. This chapter will also cover the evaluation of these models. A time-based evaluation is also done on the classification model.

5.1. Domain model development

The data used in this section are as described in Section 3, a set of labeled domain names. To be specific, 50,146 domain names and for the model development they are split into training, validation, and testing subsets. Training set consisting of 70% of the data and then validation and testing 15% each.

Using the method explained in Section 4.1, a BiLSTM model is built. This section covers the results of the best-fitting model after hyperparameter tuning.

The BiLSTM model consists of an embedding layer, then two bidirectional BiLSTM layers followed by dense layers and dropout resulting in a feature vector for each domain name of length 32.

Fig. 11(a) presents the accuracy and Fig. 11(b) illustrates the loss after 200 epochs. Fig. 11(a) shows the learning curve without Epoch 0, as Epoch 0 is significantly lower in accuracy for both the training and validation data. Looking at the loss, the training and validation losses are close to each other up to around epoch 75. After that, the lines start to separate a bit more. The same trend can be seen with the accuracy; the validation accuracy starts to decline around epoch 100, showing a lower trend in the validation accuracy. This is not a huge difference in trends, but it all suggests that the model has started to overfit to the training data, causing a decrease in the accuracy of the validation data. A peak in performance of the validation data is reached around epochs 70–75.

The same model structure is trained only for 75 epochs this time, and this model is saved and will be used for domain feature building. The accuracy and loss for this new model can be seen in Figs. 12(a) and 12(b). Table 5 shows the model accuracy and loss for training, validation, testing and domains from the certificate dataset. It is clear that within the domain dataset constructed for the domain classification, the accuracy of the model is high, but when it is used to predict the unseen data from the certificate dataset the accuracy suffers. This could be due to the domains in the certificate dataset being more processed than the domain names used for the BiLSTM model training. The domain names present in the certificate dataset have been matched with a certificate, but no such process has been done for the domain names in the other domain dataset. Therefore, even though only domain names including HTTPS were included, there are differences in the two datasets of domains.

[5] https://grantjenks.com/docs/wordsegment/.

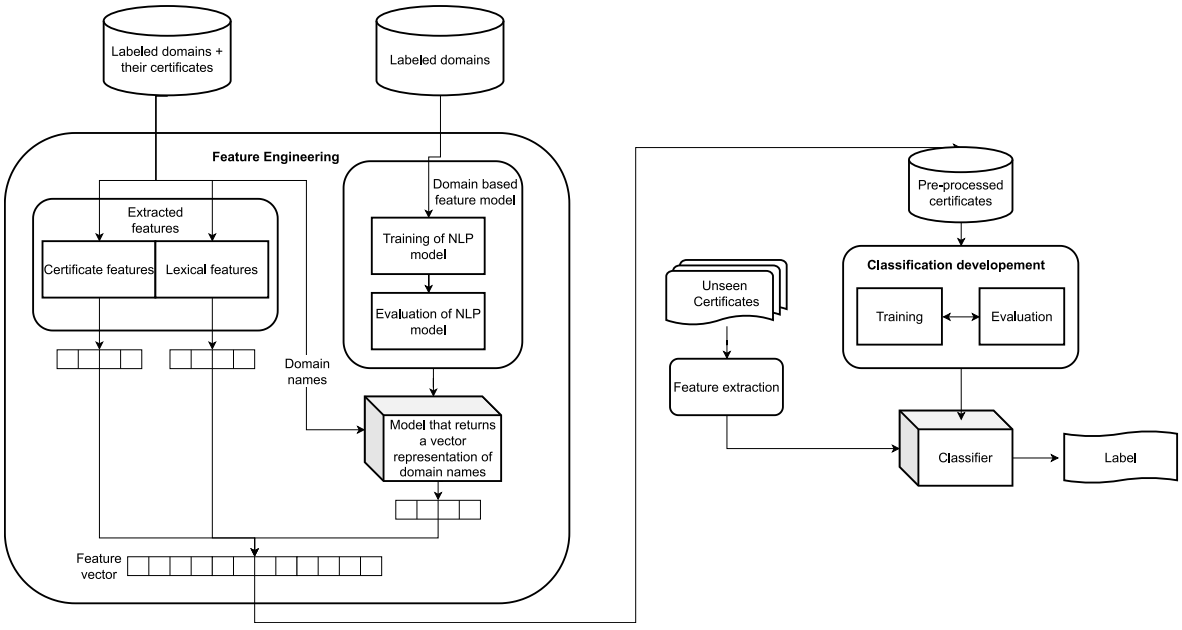


Fig. 9. Overview of the pipeline to be developed in this paper. There are two separate domain datasets, the one on the right is used for the machine learning domain related feature building and the other one on the left that is linked to certificates. Combining all features and labels from the domains, a classifier is trained and tested.

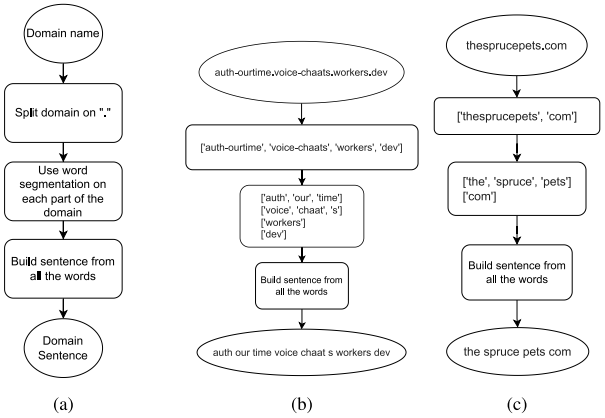
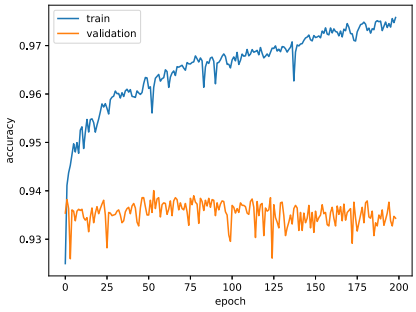


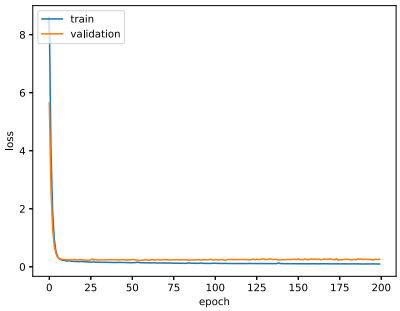
Fig. 10. Pre-processing of domain names for BiLSTM training (a) and examples of the domain name pre-processing (b) and (c).

Table 5
Model accuracy and loss for training, validation, testing, and the domains from the certificate dataset.

	Train	Validation	Test	Certificate domains
Acc.	0.97	0.94	0.93	0.77
Loss	0.13	0.24	0.26	0.59



(a) Accuracy without epoch 0



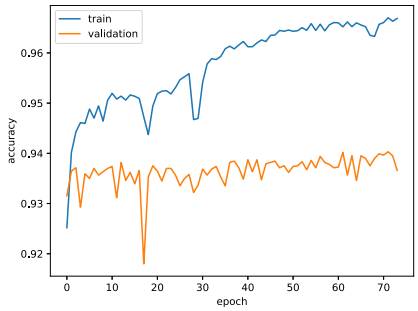
(b) Loss per epoch for training and validation

Fig. 11. Performance of the model per epoch of the BiLSTM domain classifier.

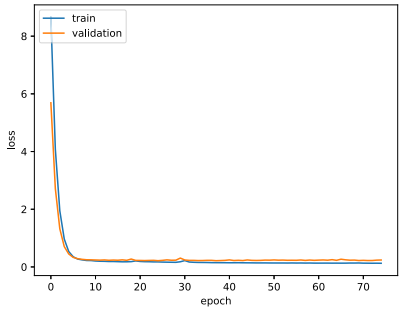
5.2. Classification model development

The data in this section are the certificate dataset described in Section 3. The dataset is balanced, so there is the same amount of phishing certificates as there are benign certificates. Our approach involved developing the classification model in three distinct steps. Initially, the model was built using only the certificate-extracted features as the base dataset. In the second step, domain-related features were added to this base and an evaluation was conducted to observe any improvements in performance. Finally, in the third step, the NLP features extracted from the domain name were included, followed by another round of evaluation. This incremental process allowed us to systematically assess the impact of adding each set of features, providing a deeper understanding of their contribution to the model's effectiveness. It should be noted that our goal was to classify digital certificates into two categories: phishing or benign, which makes it a binary classification problem. The positive samples in this section are the phishing certificates and our evaluation was made with this in mind.

The main goal of this study was to demonstrate that combining domain-related features with certificate-related features can effectively distinguish between certificates used for phishing. To maintain focus on this aspect, commonly used algorithms like Random Forest (RF),



(a) Accuracy without epoch 0.



(b) Loss per epoch of the final BiLSTM model for domain names

Fig. 12. Final BiLSTM model for domain names.

Table 6
F1-score and accuracy of a 5-fold cross-validation of certificate only based features.

Fold	RF		KNN		SVM	
	F1	Acc.	F1	Acc.	F1	Acc.
1	0.75	0.75	0.77	0.73	0.74	0.72
2	0.78	0.77	0.78	0.74	0.75	0.73
3	0.78	0.77	0.77	0.73	0.74	0.71
4	0.77	0.77	0.77	0.74	0.73	0.70
5	0.78	0.77	0.77	0.73	0.72	0.69
Average	**0.77**	**0.76**	0.77	0.74	0.74	0.71

Table 7
Confusion matrix of the classification by the RF model with only certificate related features.

		Predicted	
		False	True
Actual	False	1083	374
	True	299	1220

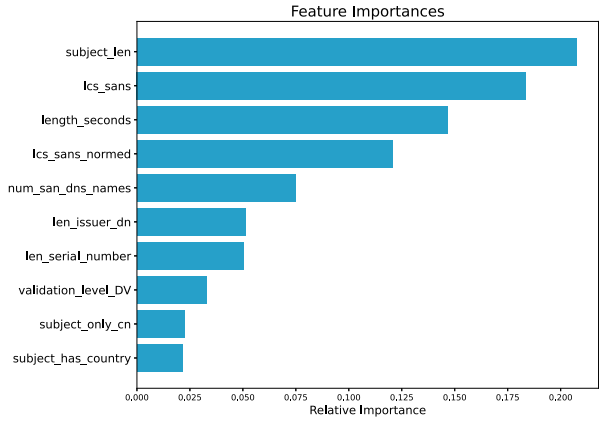


Fig. 13. Feature importance from the RF model with only certificate based features.

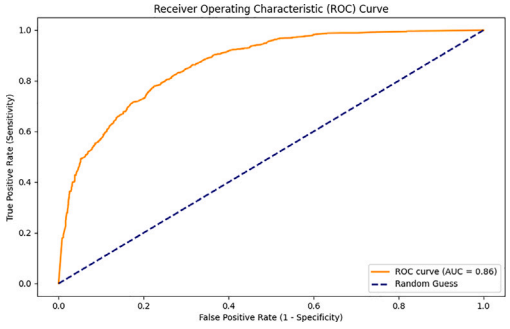


Fig. 14. ROC and AUC of the RF model based only on certificate features.

K-Nearest Neighbors (KNN), and Support Vector Machine (SVM) were chosen. These algorithms are standard and reliable methods that offer a solid baseline for comparison. The intention was to establish the concept, providing a foundation for future work where more advanced algorithms could potentially enhance performance. All models were trained using hyperparameter tuning and 5-fold cross-validation. The RF models in this section have `n_estimators=50`, the KNN models have $k = 3$ and the SVM models have a linear kernel and $c = 0.03$, as these were the best parameters for each of the models after hyperparameter tuning.

To establish a baseline model performance, a model is trained solely based on the certificate features. The results of a 5-fold cross-validation of the best performing models for each of the methods are in Table 6. The best performing method is the random forest model with an F1-score of 0.77 on average.

After 5-fold cross-validation, the data are divided into training and testing subsets, 75% for training and 25% for testing. These splits are then used to train a single RF model, as that was the best performing model. This model is used to obtain a confusion matrix and the importance of the features for this feature set. This procedure is repeated for all of the feature sets that follow.

The RF model trained on 75% of the data had an F1-score of 0.78, an MCC (Matthew's correlation coefficient) of 0.55, precision of 0.77 and recall of 0.81. We report MCC as it is a robust metric that provides a balanced measure even in the presence of imbalanced classes, giving a more comprehensive evaluation of the model's performance compared to other metrics such as accuracy or F1-score (Chicco & Jurman, 2020). Looking at the confusion matrix in Table 7, it is clear that this model is having a harder time predicting benign certificates.

To get an idea of which features are the most important, the 10 most important features are extracted from the random forest model trained on 75% of the data. A plot of the importance of the features can be seen in Fig. 13. The most influential feature is the subject length followed by the longest common subsequence of the SANs and the length in seconds, all features noted in Section 3.3 to show differences between the two groups.

Fig. 14 shows the ROC and AUC of the RF model trained on 75% of the data. The AUC is 0.86, an AUC of 1.0 means that the model has perfect performance, so a score of 0.86 is not bad but still some way to go to reach 1.0.

Now that a baseline model has been established with only certificate features, the models are trained again, now with simple domain-based features added. Again, the random forest performs the best with an average F1-score of 0.82 on average over the 5-folds or a 0.05 increase from the certificate features only.

The RF model trained on 75% of the data had an F1-score of 0.83, an MCC of 0.65, precision of 0.83 and recall of 0.81, a quite significant improvement in the MCC. The confusion matrix of this model can be

Table 8
F1-score and accuracy of a 5-fold cross-validation of certificate and simple domain based features.

Fold	RF		KNN		SVM	
	F1	Acc.	F1	Acc.	F1	Acc.
1	0.81	0.81	0.79	0.79	0.79	0.80
2	0.82	0.82	0.79	0.79	0.78	0.80
3	0.83	0.83	0.81	0.81	0.80	0.81
4	0.82	0.82	0.80	0.80	0.79	0.80
5	0.82	0.82	0.81	0.80	0.79	0.79
Average	**0.82**	**0.82**	0.80	0.80	0.79	0.80

Table 9
Confusion matrix of the classification by the RF model with certificate and domain related features.

		Predicted	
		False	True
Actual	False	1217	240
	True	279	1240

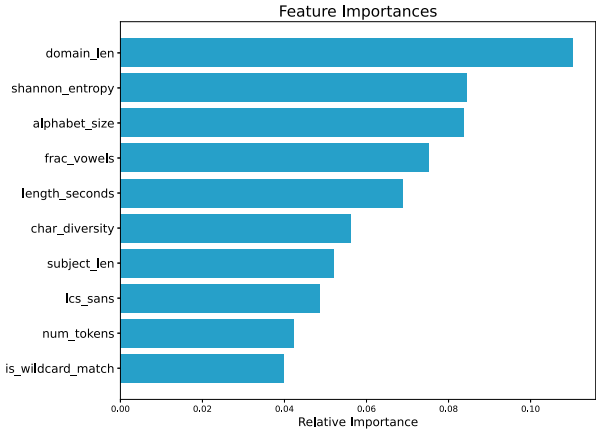


Fig. 15. Feature importance from the random forest model with certificate and domain based features.

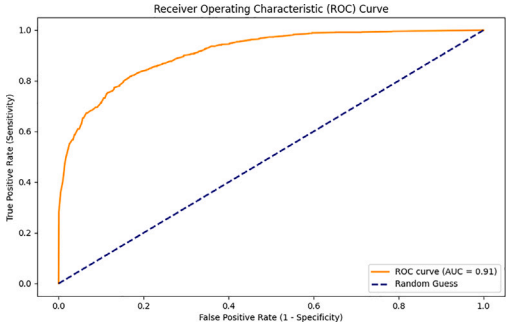


Fig. 16. ROC and AUC of the RF model based on certificate and domain based features.

seen in Table 9. Compared to Table 7, adding domain-related features increases correctly classified phishing certificates, making the balance in correctly classified certificates quite even.

Fig. 15 shows how now the subject length feature is only the 7th most important feature with domain length as the most important feature and domain-based features are taking up the top of the most important features.

Fig. 16 shows the ROC of the model. This model has an AUC of 0.91 which is an improvement from the model with only certificate-based features.

Table 10
F1-score and accuracy of a 5-fold cross-validation of certificate and SAN based features.

Fold	RF		KNN		SVM	
	F1	Acc.	F1	Acc.	F1	Acc.
1	0.79	0.79	0.76	0.76	0.74	0.74
2	0.79	0.79	0.77	0.77	0.75	0.75
3	0.80	0.79	0.79	0.78	0.76	0.75
4	0.80	0.80	0.77	0.76	0.74	0.75
5	0.81	0.80	0.79	0.78	0.75	0.74
Average	**0.80**	**0.80**	0.78	0.77	0.75	0.75

Table 11
Confusion matrix of the classification by the Random Forest model with certificate and SAN related features.

		Predicted	
		False	True
Actual	False	1165	292
	True	296	1223

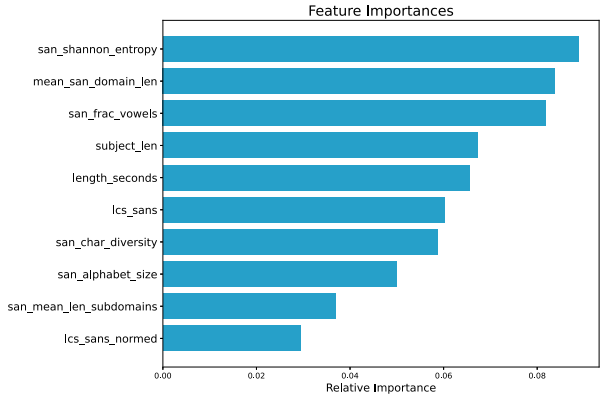


Fig. 17. Feature importance from the random forest model with certificate and SAN based features.

Next, the same models are trained again but now on the certificate features and the SAN based features. Table 10 shows the results of the model. Performing similarly to the results in Table 8, RF outperformed the other models with an F1-score of 0.80 on average. This is an improvement from the model with only certificate-based features but slightly worse than the model with the certificate- and domain-based features.

The RF model trained on 75% of the data had an F1-score of 0.81, an MCC of 0.60, precision of 0.81 and recall of 0.81. When looking at the confusion matrix for the RF model with SAN and certificate-based features (Table 11), there is an improvement in correctly classifying benign certificates compared to the model with only certificate features, but there is still some imbalance between the number of correctly classified benign and phishing certificates. That is, the set of features with the certificate and domain-based features achieves better balance between the two groups.

The importance of features for the top 10 features of the RF model is shown in Fig. 17. Here, it is the aggregated Shannon entropy, the average length of the domains in the SAN and the fraction of vowels in the SAN that are the most important features. This is similar to the domain-based feature model, as in Fig. 15 the domain based equivalent to these features is in the top four most important features.

Fig. 18 shows the ROC for the RF model based on the certificate and SAN features. It has an AUC of 0.88 which is lower than the model with certificate- and domain-based features, which is consistent with other metrics used.

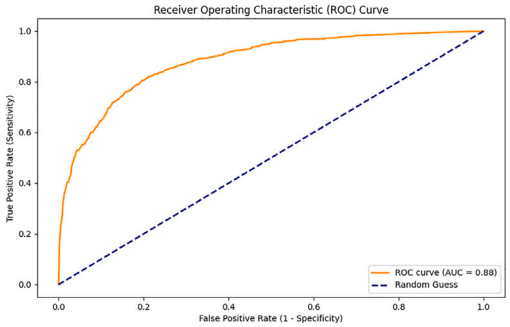


Fig. 18. ROC and AUC of the RF model based on certificate and SAN features.

Table 12
F1-score and accuracy of a 5-fold cross-validation of certificate, SAN and domain based features.

Fold	RF		KNN		SVM	
	F1	Acc.	F1	Acc.	F1	Acc.
1	0.82	0.82	0.79	0.79	0.80	0.81
2	0.82	0.82	0.80	0.80	0.79	0.80
3	0.82	0.82	0.80	0.80	0.81	0.81
4	0.83	0.83	0.80	0.80	0.80	0.81
5	0.83	0.83	0.81	0.80	0.80	0.80
Average	**0.82**	**0.82**	0.80	0.80	0.80	0.81

Table 13
Confusion matrix of the classification by the Random Forest model with certificate, SAN and domain based features.

		Predicted	
		False	True
Actual	False	1223	234
	True	277	1242

Lastly, before the BiLSTM based features are included, is a model that has all three feature sets, certificate, SAN and domain based features. The results using this feature set can be seen in Table 12. As with the previous combinations of feature sets, RF performs the best with an F1-score of 0.82 on average, the same performance for the random forest as with only certificate and domain-related features. This implies that there is nothing to be gained by including both the domain and SAN-based features. For this reason continuing on to the model with the BiLSTM features, only the certificate and domain based features will be used in addition to the BiLSTM features.

The RF model trained on 75% of the data had an F1-score of 0.83, an MCC of 0.66, precision of 0.85 and recall of 0.82. Again, the confusion matrix in Table 13 shows a better balance between the two categories compared to the model with only certificate-based features in Table 7. Similarly to the model with certificate- and domain-based features, this model achieves a decent balance in the correct classification of the two classes.

Fig. 19 shows the feature importance with all three feature sets. It is clear that the domain-based features and the certificate features are the most influential, supporting the decision to not include the SAN based features when continuing to add the BiLSTM based features.

Fig. 20 shows the ROC of the RF model based on the certificates, domain, and SAN features. The AUC of this model is 0.92 which is better than the other models so far, but it is just 0.01 higher than the model based on certificate and domain-based features.

Using the features engineered with the BiLSTM model developed in Section 5.1 in addition to the domain- and certificate-based features, the RF, KNN and SVM models are trained in the same fashion as before. In Table 14 the results of the 5-fold cross-validation are shown. The random forest model performs best with an F1-score of 0.89 on average,

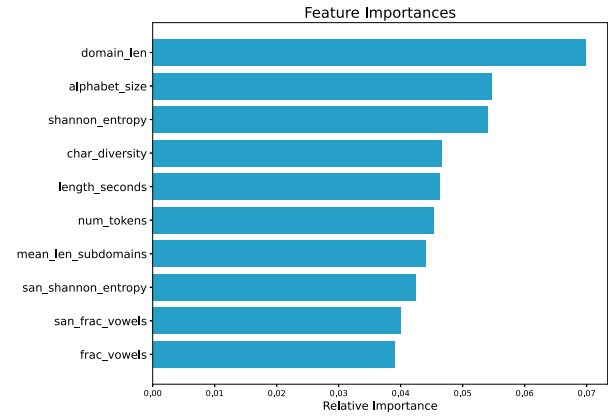


Fig. 19. Feature importance from the random forest model with certificate, domain and SAN based features.

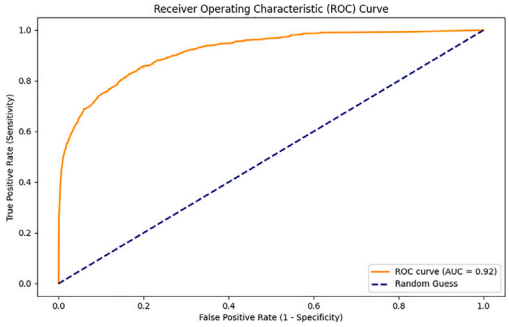


Fig. 20. ROC and AUC of the RF model based on certificate, domain and SAN based features.

Table 14
F1-score and accuracy of a 5-fold cross-validation with BiLSTM based features on domain name.

Fold	RF		KNN		SVM	
	F1	Acc.	F1	Acc.	F1	Acc.
1	0.88	0.88	0.83	0.83	0.85	0.85
2	0.89	0.89	0.84	0.84	0.84	0.84
3	0.90	0.90	0.85	0.85	0.86	0.86
4	0.89	0.89	0.84	0.84	0.85	0.86
5	0.88	0.88	0.85	0.85	0.85	0.86
Average	**0.89**	**0.89**	0.84	0.84	0.85	0.86

Table 15
Confusion matrix of the classification by the RF model, with certificate, domain and BiLSTM model based features.

		Predicted	
		False	True
Actual	False	1324	149
	True	176	1328

which is an improvement of 0.07 from the random forest model in Table 8 with the certificate and simple domain features.

The RF model trained on 75% of the data had an F1-score of 0.89, an MCC of 0.77, precision of 0.89 and recall of 0.88, which is not only an improvement in the F1-score but also an improvement in the MCC, compared to 0.65 with the certificate and simple domain features. The confusion matrix is also more balanced between the two groups, as can be seen in Table 15. But not only is it more balanced, but also the number of correctly classified observations has increased quite a bit, in accordance with the higher F1-score and MCC.

Table 16
Mean for each of the metrics in a confusion matrix within different features.

Average	TP	FN	TN	FP
domain_len	22.19	13.01	11.60	14.95
lcs_sans	14.96	10.96	10.21	13.57
shannon_entropy	3.56	3.16	3.08	3.37
subject_only_cn	0.98	0.98	0.72	0.97

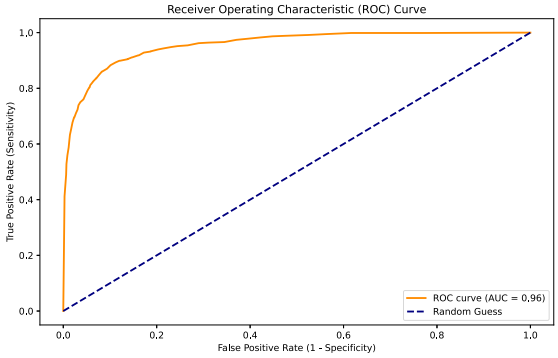


Fig. 21. ROC and AUC of the random forest model trained on the 75% of the certificate dataset.

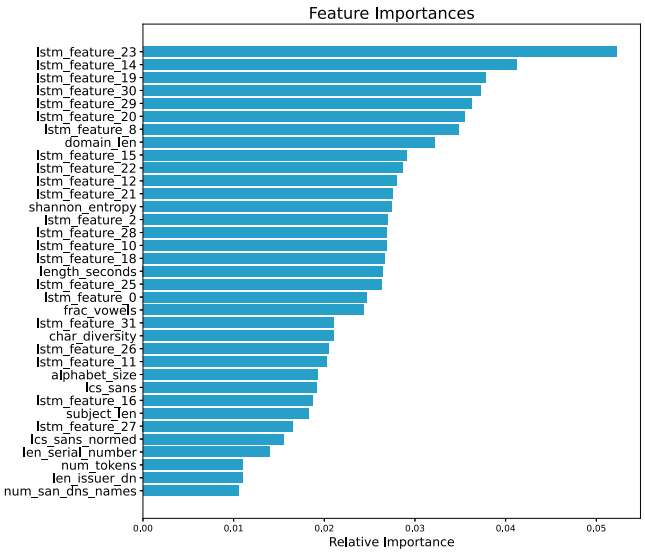


Fig. 22. Feature importance of the top 35 most important features from the random forest model with certificate, domain and BiLSTM based features.

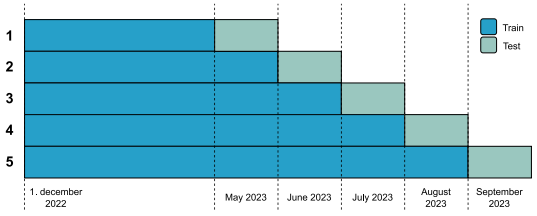


Fig. 23. Time-based split of data month by month for the last five months of the dataset.

Since this is the model that performs the best, a preliminary analysis of the wrongly classified certificate was performed. Table 16 shows how that mean of different features compares for each of the metrics in a confusion matrix. We can see that for the domain length the false negatives, that is, the phishing certificates classified as benign, the average domain length is much closer to the average length of the true benign certificates than it is to the true phishing ones. Comparing the longest common subsequence of the SANs we see that the true positives and the false negatives have similar averages and the false negatives and the true negatives are similar. For the Shannon entropy the difference is not as drastic, but still noticeable that the false negatives are closer on average to the TN and the false positives have an average close to the true positives. For *subject_only_cn* it is an average over a Boolean variable but it still shows a clear difference where the false positives clearly have this feature with value 1 most of the time, while the true negatives have more certificates with this feature as 0. Each of these features can, of course, not explain completely why the model is not able to classify the wrongly classified certificates, but it provides great insight into what features might be contributing to the miss-classification and could be used as a guide to further improve the model.

Fig. 21 shows the ROC and AUC of the model in Table 14. The AUC is 0.96, which is considered very good as an AUC of 1.0 means the model has perfect performance.

From the importance of the feature in Fig. 22 it is clear how the BiLSTM features have an impact on the classification, as the top four features are BiLSTM based features and many of the top 35 features are BiLSTM based features. A BiLSTM feature is an element of the vector representation developed from the BiLSTM model.

5.3. Time based evaluation

It cannot be assumed that trends in phishing websites or certificates will remain the same over time. That is where time-based evaluation is important. Time-based evaluation allows a system to be tested for how well it generalizes through time. To perform the time-based evaluation the dataset is split on the `not_valid_before` value of the certificates. The initial training dataset are all certificates before the 1. May 2023. Then the performance for each month is tested, one month at a time but always retraining with the new month just evaluated. Fig. 23 gives an overview of the split of the dataset and Table 17 shows the number of samples in each subset of the dataset. Due to the fact that the phishing domain names on which the dataset is built are only from websites that were still online at the time of extraction of the PhishTank list, the dataset is unbalanced when it is split up with respect to time. To address this issue, the data used for the initial training are balanced before the model is trained. When new data are added for retraining, the balance is adjusted again. This means that the data being predicted on is unbalanced, but when retraining it is balanced.

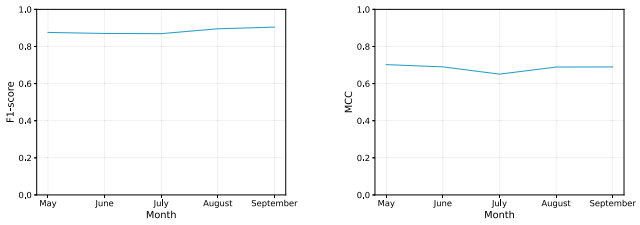
Table 17
Number of samples in the training set and each of the testing sets for the time-based evaluation.

Data split	Num. samples
Initial training set	5330
May	823
June	817
July	927
August	1132
September	1293

The results of this time-based evaluation is shown in Table 18. The best average performance for the five months is 0.88, again with the random forest model. This is in accordance with the results in Table 14. This suggests that the model generalizes well through time. There seems to be a slight trend upward in the F1-score for all models, but this is most likely due to the increase in data, making it easier to predict each month. But, as Fig. 24(a) shows, it is not a big change and Fig. 24(b) does not show the same trend in the MCC of the model.

Table 18
F1-score of the time-based evaluation for the data of each of the last five months of the dataset for each algorithm.

Month	RF	KNN	SVM
May	0.87	0.84	0.85
June	0.87	0.84	0.85
July	0.87	0.85	0.86
August	0.89	0.85	0.86
September	0.91	0.87	0.89
Average	**0.88**	0.85	0.86



(a) F1-score (b) MCC

Fig. 24. Metrics for time based evaluation for the model with the highest F1-score, Random Forest model.

6. Discussion and future works

Even though this paper has covered how to build a pipeline that can, with 89% accuracy, predict whether a website is a phishing website based on its certificate and domain name, there are a few limitations to be discussed and future work that can be done to further improve the system developed in this paper.

During our evaluation, we observed that Random Forest (RF) showed better performance compared to other algorithms studied. This could be due to the nature of the RF algorithm. Firstly, RF is an ensemble learning method that combines the predictions of multiple decision trees, which helps reduce the risk of overfitting and increases robustness. Each tree in the forest is built using a different subset of the data, which adds diversity to the model and improves generalization. Additionally, RF is less sensitive to hyperparameter settings compared to other models, making it easier to use effectively without extensive tuning. Its ability to handle large datasets with higher dimensionality also contributes to its strong performance in many cases.

The first thing to mention is the data collection process, but the data collection process. Allowing more time for data collection would allow more data to work with. With more data, other classification methods might prove successful like neural network classifiers.

Another limitation of the solution developed in this paper is phishing attacks through user-generated content on benign sites. These types of phishing attacks can, of course, not be caught by using the certificate and domain name. This is an interesting challenge for future work to try and tackle as it would require a different approach from the one presented in this paper.

To maintain a system built on the classifier in this paper, a continuous collection of new domain names and their certificates would be necessary to retrain the classifier so that it keeps up with possible changes in trends of certificates and domain names. In that context, it is also important to be aware that different languages could impact the performance. It would be beneficial to retrain such a model on specific languages as the BiLSTM model could be impacted by local factors such as language differences.

Like mentioned in Section 3, the collection of the domain names had its limitations. The choice of taking the top 20,000 certificates to represent benign domains is something that can be further investigated. Other approaches for data collection might be to take the top N domain names and take every other domain name to be used for certificate retrieval and the other for domain model training. The choice of N is then another topic for exploration, for example how much do benign domain names that are less popular differ from the top domains? Another interesting question to tackle is how many website visits belong to the top N domain names and if the answer to that could be used to guide the choice of N.

To improve the model some interesting future work can be done to analyze the wrongly classified certificate and domain pairs. Some initial work was done on this, and there seems to be a trend in the domain length of the false negatives. There was no time to finish analyzing this any further; therefore, it is left for future work.

Additionally, while our current system is a supervised binary classifier, exploring semi-supervised approaches could allow the model to learn from a larger pool of unlabeled certificates, potentially improving its adaptability. We think that unsupervised learning techniques like clustering or anomaly detection could also be used to identify new patterns, helping to flag previously unseen types of phishing attacks and further enhance the system's effectiveness.

Analyzing the importance of the features in more detail is left for future work; this includes looking into if any features can be dropped without compromising performance of the model and looking into the interaction of the domain-based features and the certificate-based features. This is because the focus here was to build on already defined feature sets to establish if the addition of domain-based features could help improve performance.

Table 19
List of symbols (Symb.) and Abbreviations (Abbr.) used in this paper.

Sym./Abbr.	Definition/Explanation
BiLSTM	Bidirectional Long Short-Term Memory, an extension of LSTM that improves model performance by processing data in both forward and backward directions
CNN	Convolutional Neural Network, a deep learning algorithm commonly used for image recognition
KNN	K-Nearest Neighbors, a simple, instance-based learning algorithm used for classification and regression
LSTM	Long Short-Term Memory, a type of recurrent neural network capable of learning long-term dependencies
MCC	Matthews Correlation Coefficient, a performance evaluation metric for binary classification
NLP	Natural Language Processing, a field of artificial intelligence concerned with the interaction between computers and humans through natural language
RF	Random Forest, an ensemble learning method for classification and regression
RNN	Recurrent Neural Network, a class of artificial neural networks where connections between nodes form a directed graph along a temporal sequence
SAN	Subject Alternative Name, an extension to the X.509 specification that allows users to specify additional host names for a single SSL certificate (used in certificates and domain names)
SVM	Support Vector Machine, a supervised learning model used for classification and regression analysis
TF-IDF	Term Frequency-Inverse Document Frequency, a numerical statistic that reflects the importance of a word in a document relative to a corpus
TLD	Top-Level Domain, the last segment of the domain name (used in domains)
URL	Uniform Resource Locator, the address of a web page

7. List of symbols and abbreviations

This section present a table of symbols and abbreviations used in this paper (see Table 19).

8. Conclusion

This paper looks at the problem of phishing attack prevention and proposes a solution based on the certificate and domain name of

the website that uses machine learning methods to predict whether a website is a phishing website or not. The data is built on domain lists from PhishTank and Tranco, while Censys was used for certificate collection. In this paper features are based on the certificate, the SANs and domain are built. An exploratory analysis is conducted on the features in which the distribution for phishing certificates and benign certificates is compared.

In addition to the aforementioned features, a BiLSTM model is developed to enrich the set of features based on the domain name. This is done by building a BiLSTM classifier and extracting the second last layer to use as a vector representation of the domain name to be used as new features for distinguishing between benign and phishing certificates. Using these feature sets in different combinations, three different machine learning classifiers, Random Forest, K-Nearest Neighbors, and Support Vector Machine, are evaluated. The best performing model was the random forest classifier with features based on the certificate, lexical domain features, and the vector representation of the domain name, with an F1-score of 0.89. By including the vector representation of the domain name, the performance increased by 0.07 compared to the model that performed best without the vector representation. Without vector representation, the models had a harder time correctly classifying benign observations compared to phishing observations, but with it included, the model manages to classify benign and phishing observations equally. The time-based evaluation resulted in an average F1-score of 0.88 which is the same as the F1-score for the 5-fold cross-validation, indicating that the model generalizes well through time.

CRediT authorship contribution statement

Magnea Haraldsdóttir: Writing – review & editing, Writing – original draft, Visualization, Validation, Software, Resources, Methodology, Investigation, Formal analysis, Data curation, Conceptualization. **Sajad Homayoun:** Writing – review & editing, Validation, Supervision, Project administration, Methodology, Investigation, Funding acquisition, Data curation. **Emil Lynge:** Resources, Data curation, Conceptualization. **Christan D. Jensen:** Supervision, Conceptualization.

Acknowledgments

This work was supported by Muninn ApS and the Innovation Fund Denmark (IFD) under the *Higher Order Threat Intelligence (HOTI): Applying Machine Learning to Network Security Metadata* project. The authors would like to thank the *Technical University of Denmark (DTU)*, where the majority of this work was carried out while Sajad, Christian and Magnea were affiliated with the institution.

Data availability

Data will be made available on request.

References

Aljabri, Malak, & Mirza, Samiha (2022). Phishing attacks detection using machine learning and deep learning models. In *2022 7th international conference on data science and machine learning applications* CDMA, (pp. 175–180). http://dx.doi.org/10.1109/CDMA54072.2022.00034.

AlSabah, Mashael, Nabeel, Mohamed, Boshmaf, Yazan, & Choo, Euijin (2022). Content-agnostic detection of phishing domains using certificate transparency and passive DNS. In *25th international symposium on research in attacks, intrusions and defenses*. ACM, http://dx.doi.org/10.1145/3545948.3545958.

Burton, Renée (2022). Alexa retired its domain rankings. Go one better with InfoRanks — blogs.infoblox.com. https://blogs.infoblox.com/security/alexa-retired-its-domain-rankings-go-one-better-with-inforanks/. (Accessed 22 July 2024).

Chicco, Davide, & Jurman, Giuseppe (2020). The advantages of the matthews correlation coefficient (MCC) over F1 score and accuracy in binary classification evaluation. *BMC Genomics*, *21*(1), 6, https://creativecommons.org/licenses/by/4.0, Springer Science and Business Media LLC.

Dong, Zheng, Kapadia, Apu, Blythe, Jim, & Jean Camp, L (2015). Beyond the lock icon: real-time detection of phishing websites using public key certificates. In *2015 APWG symposium on electronic crime research (eCrime)*. IEEE, http://dx.doi.org/10.1109/ecrime.2015.7120795.

Drichel, Arthur, Drury, Vincent, Brandt, Justus von, & Meyer, Ulrike (2021). Finding Phish in a Haystack: A pipeline for phishing classification on certificate transparency logs. In *Proceedings of the 16th international conference on availability, reliability and security*. ACM, http://dx.doi.org/10.1145/3465481.3470111.

Durumeric, Zakir, Adrian, David, Mirian, Ariana, Bailey, Michael, & Alex Halderman, J (2023). A search engine backed by Internet-Wide Scanning. In *22nd ACM conference on computer and communications security*.

Fasllija, Edona, Enişer, Hasan Ferit, & Prünster, Bernd (2019). *Lecture notes of the institute for computer sciences, social informatics and telecommunications engineering, Phish-hook: detecting phishing certificates using certificate transparency logs*. Springer International Publishing, http://dx.doi.org/10.1007/978-3-030-37231-6_18.

FBI Internet Crime Complaint Center (2022). Internet Crime report 2022. https://www.ic3.gov/Media/PDF/AnnualReport/2022_IC3Report.pdf. (Accessed 2023).

Federal Trade Commission (2022). How to recognize and avoid phishing scams. https://consumer.ftc.gov/articles/how-recognize-and-avoid-phishing-scams#report. (Accessed 21 January 2024).

Hageman, Kaspar, Kidmose, Egon, Hansen, René, & Pedersen, Jens (2021). Can a TLS certificate be phishy? In *Proceedings of the 18th international conference on security and cryptography*. SCITEPRESS - Science and Technology Publications, http://dx.doi.org/10.5220/0010516600380049.

Hawanna, Varsharani, Kulkarni, Vrushali, Rane, Rashmi, & Joshi, Pooja (2016). Risk evaluation of x.509 certificates – A machine learning application. In *Information systems security*. Springer International Publishing, http://dx.doi.org/10.1007/978-3-319-49806-5_20.

Hawanna, Varsharani, Kulkarni, V. Y, Rane, R. A, Mestri, P, & Panchal, S (2016). Risk rating system of X.509 certificates. *Procedia Computer Science*, *89*, http://dx.doi.org/10.1016/j.procs.2016.06.027.

Homayoun, Sajad, Hageman, Kaspar, Afzal-Houshmand, Sam, Jensen, Christian D., & Pedersen, Jens M. (2022). Detecting ambiguous phishing certificates using machine learning. In *2022 international conference on information networking*. ICOIN, IEEE, http://dx.doi.org/10.1109/icoin53446.2022.9687264.

Ishida, Y, Hanada, M, Waseda, A, & Kim, M. W (2023). Analysis of DNS graph of phishing websites using digital certificates. In *2023 25th international conference on advanced communication technology (ICACT)*. IEEE, http://dx.doi.org/10.23919/ICACT56868.2023.10079566.

Karim, Abdul, Shahroz, Mobeen, Mustofa, Khabib, Belhaouari, Samir Brahim, & Ramana Kumar Joga, S (2023). Phishing detection system through hybrid machine learning based on URL. *IEEE Access*, *11*, 36805–36822. http://dx.doi.org/10.1109/ACCESS.2023.3252366.

Leskovec, Jure, Rajaraman, Anand, & Ullman, Jeffrey David (2020). *Mining of massive datasets* (3rd ed). Cambridge, England: Cambridge University Press.

Li, Jiaxin, Zhang, Zhaoxin, & Guo, Changyong (2021). Machine learning-based malicious X.509 certificates' detection. *Applied Sciences*, *11*(5), 2164. http://dx.doi.org/10.3390/app11052164, MDPI AG.

Page, Matthew J., McKenzie, Joanne E., Bossuyt, Patrick M., Boutron, Isabelle, Hoffmann, Tammy C., Mulrow, Cynthia D., et al. (2021). The PRISMA 2020 statement: an updated guideline for reporting systematic reviews. *Systematic Reviews*, *10*(1), http://dx.doi.org/10.1186/s13643-021-01626-4, Springer Science and Business Media LLC.

Phishing activity trends report, Q2 2021. (2021). https://docs.apwg.org/reports/apwg_trends_report_q2_2021.pdf. (Accessed 11 January 2024).

Pochat, Victor Le, Goethem, Tom Van, Tajalizadehkhoob, Samaneh, Korczyński, Maciej, & Joosen, Wouter (2019). Tranco: A research-oriented top sites ranking hardened against manipulation. In *Proceedings of the 26th annual network and distributed system security symposium*. NDSS 2019, http://dx.doi.org/10.14722/ndss.2019.23386.

Rethlefsen, Melissa L., Kirtley, Shona, Waffenschmidt, Siw, Ayala, Ana Patricia, Moher, David, Page, Matthew J., et al. (2021). PRISMA-s: an extension to the PRISMA statement for reporting literature searches in systematic reviews. *Systematic Reviews*, *10*(1), http://dx.doi.org/10.1186/s13643-020-01542-z, Springer Science and Business Media LLC.

Sakurai, Yuji, Watanabe, Takuya, Okuda, Tetsuya, Akiyama, Mitsuaki, & Mori, Tatsuya (2020). Discovering HTTPSified phishing websites using the TLS certificates footprints. In *2020 IEEE European symposium on security and privacy workshops*. IEEE, http://dx.doi.org/10.1109/eurospw51379.2020.00077.

Salahdine, Fatima, El Mrabet, Zakaria, & Kaabouch, Naima (2021). Phishing attacks detection a machine learning-based approach. In *2021 IEEE 12th annual ubiquitous computing, electronics & mobile communication conference* UEMCON, (pp. 0250–0255). http://dx.doi.org/10.1109/UEMCON53757.2021.9666627.

Segaran, Toby, & Hammerbacher, Jeff (2009). *Beautiful data*. Sebastopol, CA: O'Reilly Media.

Torroledo, Ivan, Camacho, Luis David, & Bahnsen, Alejandro Correa (2018). Hunting Malicious TLS certificates with deep neural networks. In *Proceedings of the 11th ACM workshop on artificial intelligence and security*. ACM, http://dx.doi.org/10.1145/3270101.3270105.

Tyagi, Ishant, Shad, Jatin, Sharma, Shubham, Gaur, Siddharth, & Kaur, Gagandeep (2018). A novel machine learning approach to detect phishing websites. In *2018 5th international conference on signal processing and integrated networks* SPIN, (pp. 425–430). http://dx.doi.org/10.1109/SPIN.2018.8474040.